

Security+ 3.1 · Other Infrastructure Concepts

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 3.1 — Other Infrastructure Concepts (14:24)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: VM (hypervisor virtualiza o hardware — isolamento forte); container (Docker — roda na kernel do host, leve, isolamento mais fraco por default); ICS/OT (Sistemas industriais: PLC controla a fábrica; SCADA monitora; MUITO patch-hard — ar gap, USB é o vetor, protocolos Modbus/DNP3). IoT/embedded devices: RTOS, superfície esquecida.

Highlights que a prova cobra

- VM: isolamento STRONG (hypervisor). Container: mais leve, compartilha kernel
- ICS/OT (fábrica, usina): patch MUITO difícil — air gap, DMZ industrial
- IoT/devices: superfície GIGANTE e PATCH-fraco

Dicas de prova & Cenários Típicos

- 'isolated with strong boundary' = VM; 'shares kernel with host' = container
- 'sistema industrial isolado com protocolo especial' = ICS/OT

Cenário clássico de exame: Cenário: 'planta industrial com PLC conectado à rede de negócios' = ICS/OT risk — isolamento obrigatório.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 3.1 — Other Infrastructure Concepts)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Isolar FISICAMENTE um sistema crítico da rede (sem nenhuma conexão):

- A) Air gap
- B) VLAN
- C) VPN
- D) NAT

2. Cenário corporativo (Other Infrastructure Concepts): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'VM: isolamento STRONG (hypervisor). Container: mais leve, compartilha kernel'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: VM: isolamento STRONG (hypervisor). Container: mais leve, compartilha kernel...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

3. Cenário corporativo (Other Infrastructure Concepts): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'ICS/OT (fábrica, usina): patch MUITO difícil — air gap, DMZ industrial'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: ICS/OT (fábrica, usina): patch MUITO difícil — air gap, DMZ industrial...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Other Infrastructure Concepts): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'IoT/devices: superfície GIGANTE e PATCH-fraco'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: IoT/devices: superfície GIGANTE e PATCH-fraco...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Other Infrastructure Concepts): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'isolated with strong boundary' = VM; 'shares kernel with host' = container'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'isolated with strong boundary' = VM; 'shares kernel with host' = container...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Other Infrastructure Concepts): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'sistema industrial isolado com protocolo especial' = ICS/OT'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'sistema industrial isolado com protocolo especial' = ICS/OT...

7. Cenário corporativo (Other Infrastructure Concepts): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'Cenário: 'planta industrial com PLC conectado à rede de negócios' = ICS/OT risk — isolamento obrigatório.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário: 'planta industrial com PLC conectado à rede de negócios' = ICS/OT ...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Other Infrastructure Concepts): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'VM: isolamento STRONG (hypervisor). Container: mais leve, compartilha kernel'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: VM: isolamento STRONG (hypervisor). Container: mais leve, compartilha kernel...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Other Infrastructure Concepts): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'ICS/OT (fábrica, usina): patch MUITO difícil — air gap, DMZ industrial'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: ICS/OT (fábrica, usina): patch MUITO difícil — air gap, DMZ industrial...

10. Cenário corporativo (Other Infrastructure Concepts): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.1), um analista avalia o seguinte requisito técnico: 'IoT/devices: superfície GIGANTE e PATCH-fraco'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: IoT/devices: superfície GIGANTE e PATCH-fraco...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — Air gap.

✓ **Por que está certa:** Air gap (ou isolamento físico) é a prática de separar fisicamente um sistema crítico de qualquer rede, incluindo Internet, LAN e WAN, de modo que não haja conexão física ou lógica. Isso impede ataques remotos e exfiltração de dados por rede. É usado em ambientes de alta segurança, como sistemas de controle industrial (ICS/SCADA), redes militares e sistemas de votação. Conforme o objetivo SY0-701 3.3 (arquitetura de segurança) e 4.1 (controles de segurança), air gap é a medida mais forte de isolamento. A questão descreve exatamente isolar fisicamente um sistema crítico da rede sem nenhuma conexão, que é a definição de air gap.

✗ **Por que as outras estão erradas:**

- **VLAN:** VLAN (Virtual Local Area Network) é uma segmentação lógica de uma rede física, criada em switches, que permite separar domínios de broadcast e aplicar políticas de segurança. Embora melhore o isolamento lógico, não é um isolamento físico; dispositivos em VLANs diferentes ainda compartilham a mesma infraestrutura física e podem ser interconectados por roteamento ou configuração incorreta. A questão exige isolamento FÍSICO sem nenhuma conexão, o que VLAN não proporciona, pois mantém conectividade lógica e física subjacente.
- **VPN:** VPN (Virtual Private Network) é um túnel criptografado que permite comunicação segura através de redes não confiáveis, como a Internet. Ela fornece confidencialidade e integridade, mas não isola fisicamente o sistema; pelo contrário, conecta o sistema a uma rede remota de forma segura. A questão pede isolamento físico sem nenhuma conexão, o que é incompatível com VPN, que pressupõe conectividade de rede.
- **NAT:** NAT (Network Address Translation) é uma técnica que traduz endereços IP privados para públicos (e vice-versa), permitindo que vários dispositivos compartilhem um único endereço IP público. Ele oculta a topologia interna, mas não isola fisicamente; o sistema continua conectado à rede. A questão exige isolamento físico sem conexão, o que NAT não oferece, pois é um mecanismo de roteamento que mantém a conectividade.

2) C — Implementar a solução correspondente: VM: isolamento STRONG (hypervisor).

Container: mais leve, compartilha kernel....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Other Infrastructure Concepts): VM: isolamento STRONG (hypervisor). Container: mais leve, compartilha kernel.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

3) B — Implementar a solução correspondente: ICS/OT (fábrica, usina): patch MUITO difícil — air gap, DMZ industrial....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Other Infrastructure Concepts): ICS/OT (fábrica, usina): patch MUITO difícil — air

gap, DMZ industrial.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) A — Implementar a solução correspondente: IoT/devices: superfície GIGANTE e PATCH-fraco....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Other Infrastructure Concepts): IoT/devices: superfície GIGANTE e PATCH-fraco.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) A — Implementar a solução correspondente: 'isolated with strong boundary' = VM; 'shares kernel with host' = container....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Other Infrastructure Concepts): 'isolated with strong boundary' = VM; 'shares kernel with host' = container.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: 'sistema industrial isolado com protocolo especial' = ICS/OT....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Other Infrastructure Concepts): 'sistema industrial isolado com protocolo especial' = ICS/OT.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: Cenário: 'planta industrial com PLC conectado à rede de negócios' = ICS/OT

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Other Infrastructure Concepts): Cenário: 'planta industrial com PLC conectado à rede de negócios' = ICS/OT risk — isolamento obrigatório..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: VM: isolamento STRONG (hypervisor). Container: mais leve, compartilha kernel....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Other Infrastructure Concepts): VM: isolamento STRONG (hypervisor). Container: mais leve, compartilha kernel.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: ICS/OT (fábrica, usina): patch MUITO difícil — air gap, DMZ industrial....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Other Infrastructure Concepts): ICS/OT (fábrica, usina): patch MUITO difícil — air gap, DMZ industrial.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: IoT/devices: superfície GIGANTE e PATCH-fraco....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.1 (Other Infrastructure Concepts): IoT/devices: superfície GIGANTE e PATCH-fraco.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.